

DPDP COMPLIANCE AUDIT

taskmaster

Digital Personal Data Protection Act 2023

80/100

Grade B

Adequate

Scanned: 25 March 2026

Files indexed: 18

Languages: Node.js, Express, Mongoose, React, Next.js, JWT

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user name, email, and password for authentication and task management. The biggest DPDP risk is the potential for unauthorized access to user credentials and task data due to the absence of explicit consent mechanisms for data processing and the storage of JWT tokens in localStorage.

Validation Summary Rule findings: 13 confirmed, 1 false positives suppressed • AI gaps: 2 dual-validated • Score: 81 (rules) → 80 (integrated)

Total findings: 15

HIGH: 3

MEDIUM: 3

INFO: 3

PASS: 5

Tech Stack: Node.js, Express, Mongoose, React, Next.js

Risk Profile: The application collects user name, email, and password for authentication and task management. The biggest DPDP risk is the potential for unauthorized access to user credentials and task data due to the absence of explicit consent mechanisms for data processing and the storage of JWT tokens in localStorage.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	14/22 (64%)	WARN
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	0/8 (0%)	FAIL
Section 8(6)	8	8/8 (100%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.9–7.0 engineering days

Rule	Section	Severity	File
CONSENT_MISSING_REPO_LEVEL	Section 6 — Consent	HIGH	REPO-WIDE
AUDIT_TRAIL_MISSING	Section 8(4) — Audit Trail	HIGH	N/A
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A

INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	frontend/src/context/AuthContext.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	frontend/src/app/dashboard/page.tsx
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	N/A
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	frontend/src/context/AuthContext.tsx
	Section 9 — Children	MEDIUM	
	Section 8 — Right to Access	MEDIUM	

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (9–32 hours)

Fix immediately — these represent the highest legal exposure.

- Consent Missing Repo Level — REPO-WIDE (4–16 hrs)
- Audit Trail Missing (4–12 hrs)
- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (6–24 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Incomplete Deletion Coverage (2–8 hrs)
- (2–8 hrs)
- (2–8 hrs)

Week 4 — Advisory (2–8 hours)

Address before next compliance review.

- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 17–64 hours (2.1–8.0 engineering days)

Details

Finding 1 of 15

[Section 6 — Consent]

1. [HIGH] CONSENT_MISSING_REPO_LEVEL — CODEBASE-WIDE**Estimated fix time:** 4–16 hours

No consent mechanism detected anywhere in the repository.

Risk:

The absence of a consent mechanism means the application is not obtaining explicit permission from users before processing their personal data, which is a direct violation of DPDP Section 6.

Fix:

1. Implement a consent management system in the frontend (e.g., using a modal or checkbox during registration/profile setup) to obtain explicit user consent for data processing activities.
2. Modify backend API endpoints (e.g., user registration, profile updates) to record and verify user consent before processing personal data.
3. Create a dedicated API endpoint to allow users to view and manage their consent preferences.
4. Update user data models to include fields for consent status and timestamps.

DPDP:

Section 6 — Consent: Requires obtaining freely given, specific, informed, and unambiguous consent for the processing of personal data.

Example:

```
typescript // frontend/src/components/ConsentModal.tsx import React, { useState } from
'react'; interface ConsentModalProps { onConsentGiven: (consent: boolean) => void; } const
ConsentModal: React.FC<ConsentModalProps> = ({ onConsentGiven }) => { const [agreed,
setAgreed] = useState(false); const handleConfirm = () => { onConsentGiven(agreed); }; return
( <div> <p>We need your consent to process your data...</p> <label> <input type="checkbox"
checked={agreed} onChange={(e) => setAgreed(e.target.checked)} /> I agree </label> <button
onClick={handleConfirm} disabled={!agreed}>Continue</button> </div> ); }; export default
ConsentModal;
```

Finding 2 of 15

[Section 8(4) — Audit Trail]

2. [HIGH] AUDIT_TRAIL_MISSING — N / A:1

Evidence snippet: This frontend file handles authentication but does not contain any logging for API requests or user actions.

Estimated fix time: 4–12 hours

No audit trail infrastructure detected. DPDP Section 8(4) requires complete records of personal data processing activities. No access logging, audit model, or change tracking found in the codebase.

Risk:

The absence of an audit trail means there are no records of who accessed or modified personal data, making it impossible to comply with accountability requirements and investigate potential data breaches.

Fix:

1. Implement a centralized logging mechanism in the backend (e.g., using Winston or Pino) to record all API requests, especially those involving personal data.
2. Create an audit log model in the database to store details of data access, modification, and deletion events, including user ID, timestamp, action, and affected data.
3. Integrate logging calls within controllers and middleware to capture relevant events, such as user login/logout, data retrieval, updates, and deletions.
4. Ensure logs are stored securely and retained according to policy.

DPDP:

Section 8(4) — Audit Trail: Requires maintaining complete records of personal data processing activities.

Example:

```
javascript // backend/middleware/auditMiddleware.js const AuditLog =
require('../models/AuditLog'); // Assuming you have an AuditLog model const auditLog = async
(req, res, next) => { const userId = req.user ? req.user._id : 'anonymous'; const action =
`${req.method} ${req.originalUrl}`; const timestamp = new Date(); try { await
AuditLog.create({ userId, action, timestamp, ipAddress: req.ip }); } catch (error) {
console.error('Audit logging failed:', error); } next(); }; module.exports = auditLog; //
backend/routes/taskRoutes.js (example integration) const auditLog =
require('../middleware/auditMiddleware'); router.route('/').get(protect, auditLog,
getTasks).post(protect, auditLog, createTask);
```

Finding 3 of 15

[Section 13 — Grievance Redressal]

3. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A:1

Evidence snippet: This frontend file manages user authentication and does not contain any information or contact details for a Grievance Officer or DPO.

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of published contact information for a Grievance Officer or Data Protection Officer (DPO) prevents data subjects from easily lodging complaints or seeking redressal, hindering their rights under the DPDP Act.

Fix:

1. Create a new page or section in the frontend (e.g., 'Contact Us' or 'Privacy Policy') to display the contact details of the designated Grievance Officer or DPO.
2. Include the Grievance Officer's/DPO's name, title, email address, and optionally, a phone number and physical address.
3. Ensure this information is easily accessible from the application's main navigation or footer.
4. Consider creating a dedicated contact form or route for grievance submissions if required.

DPDP:

Section 13 — Grievance Redressal: Requires appointing a Grievance Officer to address data principal grievances and publishing their contact details.

Example:

```
html <!-- frontend/pages/privacy.tsx --> import React from 'react'; const PrivacyPolicy:
React.FC = () => { return ( <div> <h1>Privacy Policy</h1> {/* ... other policy content ... */}
<h2>Grievance Redressal</h2> <p>If you have any concerns or wish to lodge a complaint
regarding your personal data, please contact our Grievance Officer:</p>
<p><strong>Name:</strong> [Grievance Officer Name]</p> <p><strong>Email:</strong> <a
href="mailto:[grievance.officer@example.com]">[grievance.officer@example.com]</a></p>
<p><strong>Phone:</strong> [Grievance Officer Phone Number]</p> </div> ); }; export default
PrivacyPolicy;
```

Finding 4 of 15

[Section 8 — Data Principal Rights]

4. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A:1

Evidence snippet: This frontend file manages user authentication and does not contain any logic for handling data deletion requests.

Estimated fix time: 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: backend/config/db.js, backend/models/Task.js, backend/models/User.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

The lack of a comprehensive data deletion mechanism means that personal data may persist longer than necessary or after a user's request, violating the right to erasure and data minimization principles.

Fix:

1. Implement a dedicated API endpoint (e.g., `DELETE /users/me/data`) in `userRoutes.js` to handle data deletion requests initiated by the user.
2. In the corresponding controller (`userController.js`), add logic to permanently delete or anonymize all personal data associated with the user across all relevant database tables.
3. Ensure that the `deleteTask` route in `taskRoutes.js` also handles the deletion of any personal data linked to the task, not just the task record itself.
4. Consider implementing a confirmation step for users before irreversible data deletion.

DPDP:

Section 8 — Data Principal Rights: Includes the right to erasure, requiring organizations to delete personal data upon request.

Example:

```
javascript // backend/controllers/userController.js const User = require('../models/User');
const Task = require('../models/Task'); // Assuming Task model exists // ... other controller
functions ... exports.deleteUserData = async (req, res) => { try { const userId =
req.user._id; // Delete user's tasks await Task.deleteMany({ userId: userId }); // Delete user
account await User.findByIdAndDelete(userId); // Add logic here to delete any other associated
personal data res.status(200).json({ message: 'User data deleted successfully' }); } catch
(error) { res.status(500).json({ message: 'Error deleting user data', error: error.message });
} }; // backend/routes/userRoutes.js const userController =
require('../controllers/userController'); const { protect } =
require('../middleware/authMiddleware'); router.delete('/profile/data', protect,
userController.deleteUserData);
```

Finding 5 of 15

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data export feature means users cannot obtain a copy of their personal data in a machine-readable format, which is a requirement under DPDP Section 11. This can lead to user dissatisfaction and potential non-compliance penalties.

Fix:

1. Create a new API endpoint (e.g., `/users/export-data`) in `backend/routes/userRoutes.js` that is protected by authentication.
2. Implement a controller function in `backend/controllers/userController.js` to fetch the authenticated user's personal data.
3. Format the fetched data into a commonly used machine-readable format such as JSON.
4. Return the formatted data as a downloadable file (e.g., `user\_data.json`) from the API endpoint.

DPDP:

Section 11 — Data Portability requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Example:

```
javascript // backend/routes/userRoutes.js // ... other imports const { exportUserData } =
require('../controllers/userController'); // ... existing routes router.get('/profile/export',
protect, exportUserData); // ... module.exports javascript //
backend/controllers/userController.js // ... other imports and functions const exportUserData
= async (req, res) => { try { // Fetch user data based on req.user.id const userData = await
User.findById(req.user.id).select('-password'); // Exclude password if (!userData) { return
res.status(404).json({ message: 'User not found' }); } // Format data to JSON const jsonData =
JSON.stringify(userData, null, 2); // Set headers for download
res.setHeader('Content-disposition', 'attachment; filename=user_data.json');
res.setHeader('Content-type', 'application/json'); res.send(jsonData); } catch (error) {
console.error('Error exporting user data:', error); res.status(500).json({ message: 'Failed to
export data' }); } }; // ... module.exports including exportUserData
```

Finding 6 of 15

[Section 5 — Notice]

6. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 7 of 15

[Section 5 — Purpose Limitation]

7. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 8 of 15

[Section 16 — Cross-Border Transfer]

8. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 9 of 15

[Section 6 — Consent]

9. [PASS] CONSENT_PRESENT — frontend / src / context / AuthContext.tsx

Auth enforcement pattern detected inline — consent likely handled at registration.

Finding 10 of 15

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — frontend / src / app / dashboard / page.tsx

Auth enforcement pattern detected inline — consent likely handled at registration.

Finding 11 of 15

[Section 8 — Data Principal Rights]

11. [PASS] DELETION_MECHANISM_PRESENT — N / A

Data deletion mechanism detected. Found 0 deletion endpoint(s) and 2 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 12 of 15

[Section 8(6) — Breach]

12. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 13 of 15

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — frontend / src / context / AuthContext.tsx

Data access endpoint detected for authenticated users.

Finding 14 of 15

[Section 9 — Children]

14. [MEDIUM] — CODEBASE-WIDE

No age verification for user registration

Finding 15 of 15

[Section 8 — Right to Access]

15. [MEDIUM] — CODEBASE-WIDE

Incomplete user data access transparency

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No age verification for user registration

Confidence: 68%

Section 9 — Children

The ``User`` model (``backend/models/User.js``) and the user registration flow (``POST /users`` handled by ``backend/controllers/userController.js`` and initiated from ``frontend/src/app/page.tsx``) do not include any fields or logic for age verification. This absence means the application cannot determine if it is processing data of children, which has specific DPDP requirements.

Recommendation: Add an age verification mechanism (e.g., date of birth field or an age confirmation checkbox) to the user registration form in ``frontend/src/app/page.tsx`` and implement corresponding validation logic in ``backend/controllers/userController.js`` and the ``User`` Mongoose schema (``backend/models/User.js``).

[AI-INFERRED] Incomplete user data access transparency

Confidence: 71%

Section 8 — Right to Access

While users can view and update their name and email via ``GET /users/profile`` and ``PUT /users/profile``, there is no dedicated 'Privacy Dashboard' or 'My Data' section in ``frontend/src/app/dashboard/page.tsx`` or other UI components that provides a comprehensive overview of *all* personal data stored (e.g., account creation date, last login, full list of data categories processed, or explicit processing purposes). This is distinct from the ``DATA_PORTABILITY_MISSING`` finding which focuses on data download.

Recommendation: Implement a dedicated 'My Data' or 'Privacy Dashboard' section within ``frontend/src/app/dashboard/page.tsx`` that displays all categories of personal data stored for the user, including relevant metadata (e.g., creation date, last update), and information about processing purposes. This would require a new backend endpoint (e.g., ``GET /users/data_summary``) in ``backend/routes/userRoutes.js`` and ``backend/controllers/userController.js``.

Deep Compliance Review

Overall Risk: CRITICAL

The application presents critical DPDP compliance risks due to pervasive PII exposure vectors, including insecure JWT storage and excessive PII handling across layers. A significant architectural gap exists in the complete absence of user account deletion functionality, directly violating data subject rights and data minimization principles. These issues, coupled with weak foundational security configurations, create a high likelihood of unauthorized access to personal data and non-compliance with data protection regulations.

Estimated remediation: 25 engineering day(s)

Most Critical Action: Migrate JWT storage from localStorage to secure, HttpOnly, SameSite=Strict cookies to prevent PII theft via XSS.

- **Inadequate Safeguards Against PII Exposure & Theft [HIGH]** — Security of personal data — layers: Authentication & Session, Configuration & Secrets, Third-Party & PII Flows, API Routes & Controllers
- **Violations of Data Minimization Principles [HIGH]** — Data minimization — layers: Authentication & Session, Data Models & Storage
- **Incomplete Implementation of Data Subject Rights [HIGH]** — Right to Erasure — layers: API Routes & Controllers

1. [HIGH] JWT in localStorage risks PII theft — N/A — Security of personal data
Storing JWTs in localStorage significantly increases the risk of PII theft via XSS attacks, compromising user credentials and session integrity.

2. [HIGH] Missing User Account Deletion Functionality — userRoutes.js, dashboard/page.tsx — Right to Erasure
Absence of a DELETE route for user profile/account and no UI element or handler for account deletion, preventing users from exercising their Right to Erasure.

3. [HIGH] Task description allows PII over-collection — N/A — Data minimization
The task description field in the data model does not restrict the type of information users can input, leading to potential over-collection of PII beyond the application's purpose.

4. [HIGH] Missing Security Headers Configuration — next.config.ts — Security of personal data
The application lacks critical security headers (e.g., Content-Security-Policy, X-Content-Type-Options) in its Next.js configuration, increasing vulnerability to common web attacks that could expose PII.

5. [MEDIUM] Global AuthContext exposes unnecessary PII — N/A — Data minimization, Security of personal data
The Global AuthContext exposes more user PII than necessary to frontend components, violating data minimization principles and increasing the surface area for accidental exposure.

Layer Breakdown

Configuration & Secrets — 2 finding(s). This configuration layer currently lacks critical security configurations for the Next.js frontend application. The absence of explicit security headers and environment variable handling in `next.config.ts` creates significant DPDP compliance risks related to data security and potential exposure of sensitive information. Addressing these omissions is crucial for establishing a robust data protection posture.

Authentication & Session — 3 finding(s). The Authentication & Session layer exhibits several critical data protection risks. Storing JWTs in `localStorage` significantly increases the risk of PII theft via XSS, while the broad exposure of user PII through both frontend context and backend request objects violates data minimization principles. Addressing these architectural patterns is crucial for enhancing the security and compliance posture of personal data handling.

Data Models & Storage — 4 finding(s). This layer defines the application's data models and database connection. While basic security for passwords is implemented, significant architectural gaps exist regarding data minimization, explicit data retention policies, and data classification within the schemas. Critical error logging also falls short of DPDP requirements for security and auditability.

Third-Party & PII Flows — 2 finding(s). This layer handles user authentication and profile management, involving the collection and processing of PII like name and email. While basic CRUD operations are present, there are compliance risks related to the potential exposure of sensitive backend error messages and insufficient input validation for PII, which could compromise data accuracy and security.

API Routes & Controllers — 2 finding(s). The API Routes and Controllers layer demonstrates basic access control for user profiles but critically lacks functionality for Data Principals to exercise their Right to Erasure for their entire account. Additionally, client-side error handling practices pose a risk of exposing sensitive information, which could undermine data security.